

区块链项目设计与安全性分析

陈润宇

对外经济贸易大学信息学院



内容提纲

- 什么是创新项目
- 区块链应用的价值判断准则
- 区块链应用的重要考量
- 区块链安全问题
- 区块链信息的安全属性
- 区块链系统的安全要求
- 区块链安全测试方法
- 区块链治理

什么是创新项目



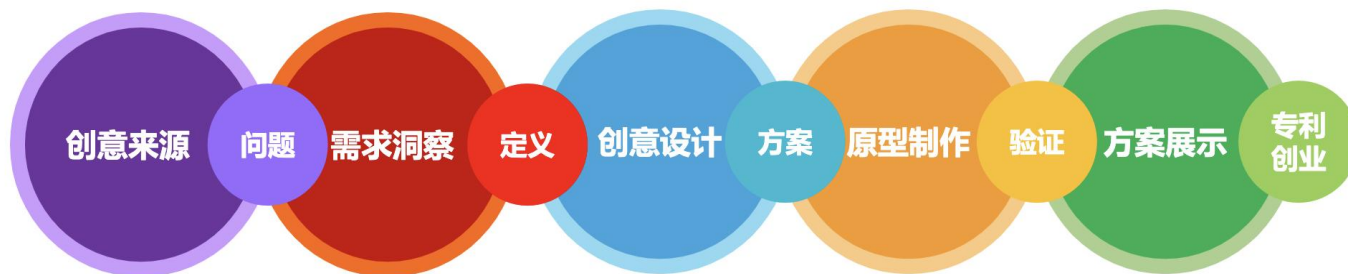
腾讯会议



钉钉

创新项目设计一定是为解决某项实际需求，我们需要去发现问题并解决问题。

创新项目设计流程



设计标准

创新项目设计评分标准

创新性

突出原始创新和技术突破的家迫，不鼓励模仿。
在商业模式、产品服务、管理运营、市场营销、工艺流程、应用场景等方面寻求突破和创新。
鼓励项目与高校科技成果转化相结合，取得一定数量和质量创新成果。（专利、创新奖励、行业认可等）

分值：40



团队情况

团队成员的教育和工作背景、创新思想、价值观念、分工协作和能力互补情况。
项目拟成立公司的组织架构，股权结构与人员配置安排合理。
创业顾问、潜在投资人以及战略合作伙伴等外部资源的使用计划和有关情况。

分值：30



商业性

商业模式设计完整、可行，项目盈利能力推导过程合理。
在商业机会识别与利用、竞争与合作、技术基础、产品或服务设计、资金及人员需求、现行法律法规限制等方面具有可行性。
项目目标市场容量及市场前景，未来对相关产业升级或颠覆的可能性，近期融资需求及资金使用规划是否合理。

分值：20



社会效益

项目发展战略和规模扩张策略的合理性和可行性，预判项目可能带动社会就业的能力。

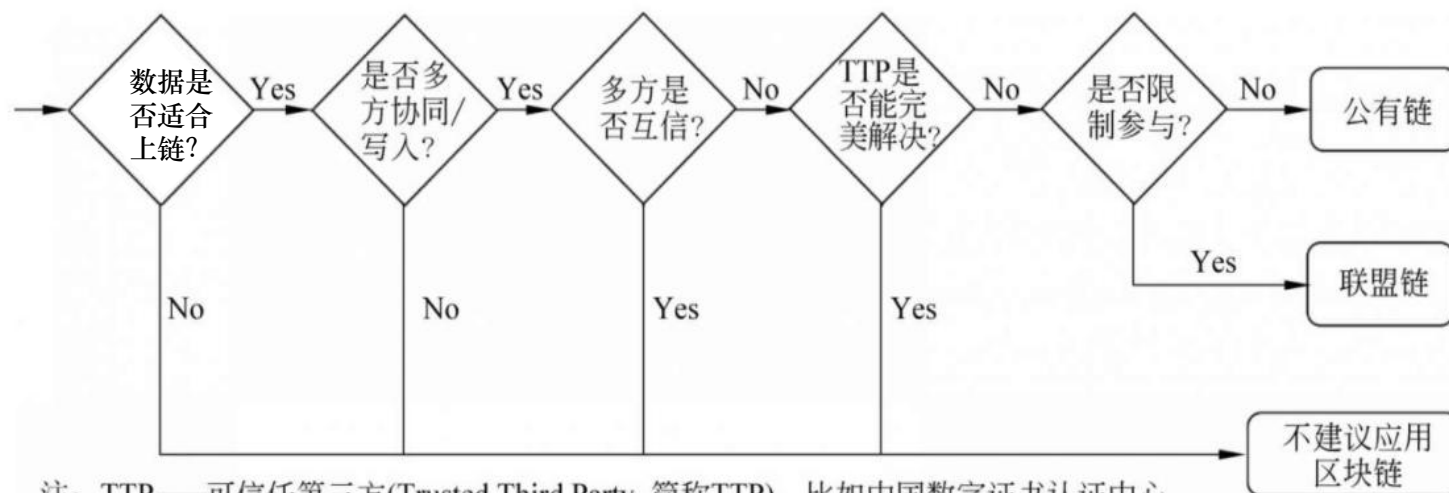
分值：10



区块链应用的价值判断准则

区块链可以运用在任何行业与领域中，但不是所有行业都需要区块链。区块链面向的行业，需要多方参与，构建行业联盟形成事实标准。在使用区块链技术之前，需要充分考虑必要性。

区块链应用决策树的五大准则——判断某场景是否需要区块链



区块链应用的价值判断准则

准则一：数据是否支持上链？

不适合上链的数据

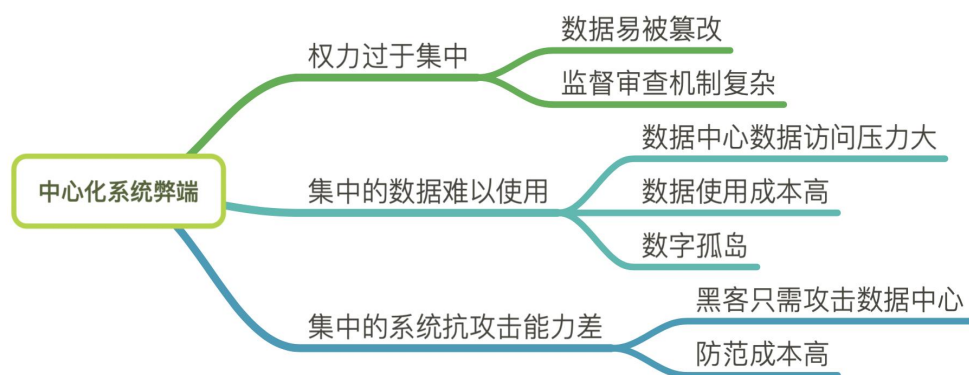
- 从保密角度来说，不需要或不想共享的数据不适合上链。例如用户的私钥，是用户绝对不想分享的信息，而如果上链则意味着被每一个区块链参与者记录并存储，即便被加密也会有泄露的风险。因此个体需要严格保密的数据不适合上链。
- 从性能角度来说，过于繁杂的数据和更新过于频繁的数据也不适合上链。比如用户上传的一些二进制的介质、一般的音频/视频、日志文件等。因为区块上存储的数据是作为链的一部分永久地保存下去，并同步到每一个参与节点用来保证完整性的。如果所有一般数据都存储上链，不仅没必要，还会严重影响同步性能，占用有限的存储空间。不仅如此，由于区块链需要密码学算法进行哈希和非对称加密运算，交易的最数据也需要通过分布式共识机制才能最终落块，对安全性与性能必将作出取舍，因此过于频繁地写人操作不太适合区块链。

适合上链的数据

- 需要共享的、具备可信度的、具备可追溯性的、不希望被篡改的、独一无二或珍贵的数据信息是适合上链的信息。交易就是一个典型的例子，这也是为什么区块链最著名的应用是加密货币，同时区块链经常被定义为“分布式账本”的原因；还有诸如保险行业的保单信息、能源领域的点对点电力交易、物流领域的物品防伪可追溯和医疗领域的患者数据共享等。

区块链应用的价值判断准则

准则二：是否存在多方协同与数据写入——系统是否需要去中心化技术



这些数据中心化的弊端，都可以依靠区块链天然的去中心化属性来解决。将中心化账本转化为去中心化账本，这样每个数据节点是对等的，都拥有完整的数据链。这样除非黑客同时攻陷大部分节点，否则不会影响数据的正确性，这就大大降低了一个数据中心的管理和防护压力。另外，分布式系统降低了数据访问的成本，增加了数据传播的效益。最后，各个节点之间也可以起到相互监督的作用，把权力从一个人手上转移出来，真正地实现数据自治。

区块链应用的价值判断准则

准则三：多方是否互信



随着互联网的大规模发展，使用TCP/IP网络通信构建出了一条条网状的信息“高速公路”。在这个“高速公路”网络上，信息能够快速生成和复制，传播到世界上每一个被互联网覆盖的角落。这种传播方法是非常高效且价格低廉的，然而人们渐渐发现，有些信息是不能在这种方式下传播的。比如对于一些私密的个人信息，我们希望互联网能够帮我们严格保密，但是事实是无用的隐私协定和猖獗的信息贩卖让互联网用户们很多时候都宛如在网络世界“裸奔”，例如著名的“双花问题”（Double-Spending Problem，即双重支付，指的是在数字货币系统中，由于数据的可复制性，使得系统可能存在同一笔数字资产因不当操作被重复使用的情况），就是想要强调在涉及价值传递时我们对数字世界本能的不信任。

如果说前代互联网解决的是数据传递的问题，那么新一代采用区块链技术的互联网旨在解决价值传递和信任的问题。



区块链应用的价值判断准则

准则三：多方是否互信

区块链技术的优势

哈希算法

数字签名

链式结构

分布算法

1. 区块链利用密码学的哈希算法和数字签名来保证交易人的身份无法被冒充交易内容无法被篡改。
2. 区块链的链式结构保证了这个分布式数据库中的历史数据无法被更改，并且透明可追溯。
3. 区块链的共识算法解决了分布式系统达成一致性的问题

区块链的一系列特点给互联网带来了一场基于信任机器的新科技革命，虚拟世界在区块链技术上建立前所未有的互信，从而构建无须信任的系统(Trustless System)。通过区块链技术，可以不用再花时间和资本去建立信任中介就可以完成价值转换。

区块链应用的价值判断准则

准则三：多方是否互信



不适用	适用
➤ 完全信任：设多方确实有足够强的信任，参与区块链(写块、读块)的多方是为了同一个目标而协作，并且相信其他人都不会为了自己的利益而做出损害集体利益的事情，那么即使在物理上分散，他们在逻辑方法和行为上也是聚合的，也就是“力往一处使”在这种情况下区块链的信任传递特性已然失去了意义。	➤ 非天然具备的完全信任：在现实的经济社会与生产活动中，大多数已存在的信任机制都是建立在一定场景下的，比如团队内部的长期沟通合作，或者不同团体之间通过可信任第三方建立。 ➤ 信任根基不牢固：这种信任的根基并不牢固，第三方可能出现中心化机构会出现的一切问题(见准则二)，而团体里的信任只能限定于一个特定的人数范围。

区块链应用的价值判断准则

准则四：TTP是否能完美解决问题

TTP的缺陷能否接受，TTP的成本能否接受

- 如果在此应用场景中已存在TTP并且能完美解决应用场景中关于价值信任的问题，那么就不需要借助区块链技术。
- 建立这种信任的权威机构是非常复杂且昂贵的，尤其是在互联网和现实世界中

TTP

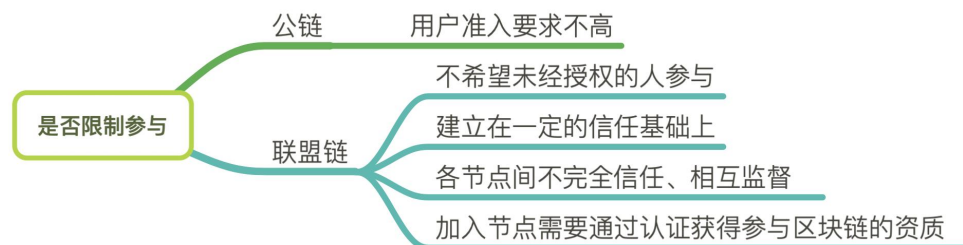
即可信任第三方，是由计算机安全领域引人的概念。顾名思义就是一个具有公信力的权威的组织机构

建立可信任第三方机构常见问题

- 昂贵的门槛费
- 复杂的接入程序
- 权力过于集中
- 信任危机

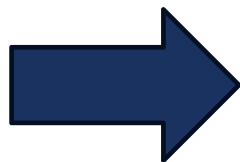
区块链应用的价值判断准则

准则五：是否限制参与



公链	联盟链
➤ 在公有链系统中，系统对节点的加入没有限制。 ➤ 以比特币系统为例，世界上的所有人都可以自由地加入(和退出)。这构建了一个公平的世界性的交易体系，但也使得系统的治理非常复杂。 ➤ 如果构建的区块链网络主要应用于客户端，需要吸引更多的用户加入维持网络活力，那么就需要考虑使用公有链系统。	➤ 为了利用区块链的特性，同时避免复杂的系统治理，采用许可认证的节点管理方式的联盟链应运而生。 ➤ 对于联盟链中的节点来说，系统是在一系列已知认证的、具有特定身份标识成员之间进行交互。 ➤ 如果开展的业务是以企业间合作为主，价值的传递主要包括企业的隐私数据、核心科技、商业机密，那么在选用区块链技术时需要采用联盟链，通过权限的方式，给加入的成员设置“门槛”，从而提高安全性

区块链应用的重要考量



关系设计

数据设计

共识设计

激励设计

区块链基础架构模型

区块链应用的重要考量

一、数据设计

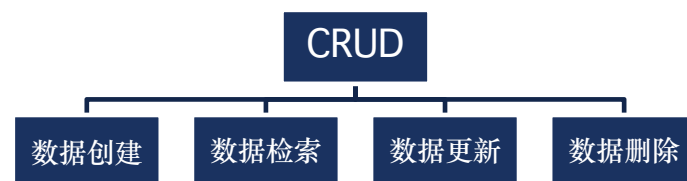
数据设计原则：考虑到区块链现阶段的性能，区块链应用的前提应是需要解决的问题本身已经互联网化，对应的数据可以标准化。通过对现有大部分领域的分析来看，区块链目前公认的天然适合的领域有金融、内容版权、医疗、慈善、能源。不难看出，这些领域都是在互联网上比较成熟，数据形式简单并符合共享性、安全性、可追溯性等要求的。

区块链应用的重要考量

二、关系设计

■传统中心化系统采用的数据操作包括CRUD(Create, Retrieve, Update, Delete), 即分别对应对数据的创建、检索更新和删除权力。

■将区块链技术理解为在去中心化系统的特殊数据库, 根据区块链种类的不同对于数据的操作也不尽相同。

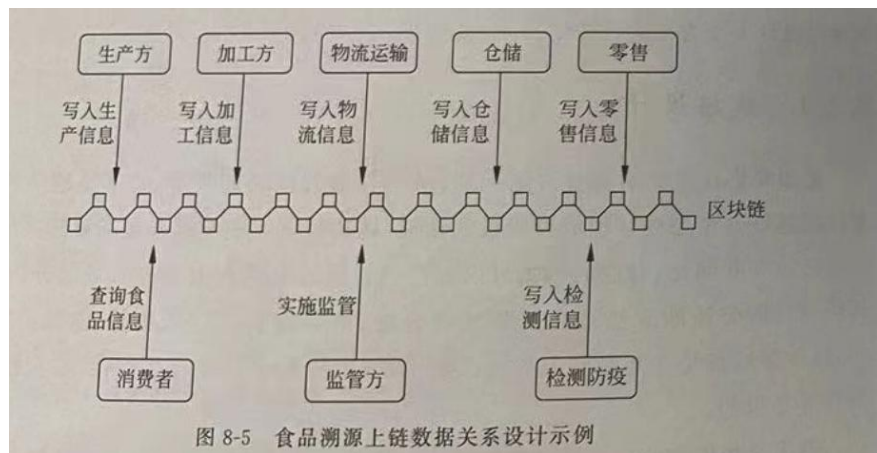


公链	联盟链	私有链
➤ 所有数据都是公开的, 人人都可以创建和读取	➤ 只有通过了申请的联盟链成员才可以读取和写入数据, 联盟链成员可以通过协议指定特定的规则	➤ 完全中心化的区块链存储方式, 只有所有者可以读写数据

区块链应用的重要考量

■ 应用示例——区块链在食品溯源中的应用

- 实现的目标：任意由消费者购买的食物都可以向前追溯到源头
- 具体细节：食品在经历生产、加工、运输、仓库和销售每个环节时都需要进行相关信息的数据上链，最终实现所有上链信息公开



食品溯源数据上链的参与方包括生产方、加工方在内的多种角色，虽然数据公开可以让所有角色都可以看到，但是不同角色由于权限不同，在数据上链时只能进行相应角色的操作，如生产方只能上链生产信息，加工方只能上链加工信息。

区块链应用的重要考量

三、共识设计

基于共识机制设计是去中心化系统设计的核心环节。针对不同的区块链系统，出于安全性、准入性以及节点规模要求，可以采用不同的共识机制算法。对于开放场景下无需许可链，例如比特币、以太坊等，采用PoW或PoS类算法是比较常见的。对于有准入限制的许可链或者联盟链来说，由于节点动态变化少，系统交易吞吐求较高，因此常采用PBFT共识的演进版本实现区块链系统。



区块链应用的重要考量

四、激励设计

- 区块链系统是一个典型的经济系统，其参与者可以通过贡献算力来获得经济激励。因为人都是有自利性的，即更倾向于采取有利于提高自身收益的行为。因此，设计一个有效的激励机制对任何区块链系统都尤其重要。
 - **激励相容性：**有一个共识机制，矿工在达到个人收益最大化的同时，也能实现整个区块链系统的价值最大化，则称这个共识机制是激励相容的。
- 如果缺乏有效的激励手段，那么社区很可能会发展为矿工只考虑自身的经济利益，进而采取一系列策略性挖矿行为，导致整体系统生态的稳定性和公平性受到有害影响。而如果共识算法是激励相容的，则在最好的情况下，所有矿工都将遵守共识协议进行诚实挖矿，从而获得与其自身算力相当的奖励。
- **综上所述：**一个好的激励设计是维持区块链生态系统稳定的核心，它可以在保证各参与方的经济利益的前提下，有效调动参与者的积极性，进而极大地提升分布式协作的效率。

区块链安全问题

安全保障的总体思路

区块链技术自身

静态分析
动态分析
模糊测试
系统漏洞挖掘
安全开发库

社区验证

漏洞悬赏计划
黑客大赛

治理机制

预警机制与应急响应
软分叉或硬分叉
监管审计节点
业务安全检测
适宜的激励机制

区块链主要安全问题

链上数据安全问题

- 链上数据安全问题主要包括非法访问用户、未经授权访问数据、密码、用户私钥窃取链上数据监管缺失、敏感数据上链泄露等。
- 应用区块链所面临的链上数据安全问题已引起广泛关注。虽然相较于传统信息系统，其采用的共识机制，更适合共享信任、传递价值，但在公有链环境下，节点未经授权，即可访问链上数据信息，包括用户地址、交易细节等，造成了严重的隐私保护难题。而在许可链环境下节点虽需获得授权才可访问链上数据信息，但因存在中心化节点，链上数据安全问题不容小觑。
- 以比特币为例，用户采用非对称加密体系的公钥作为匿名地址，来隐藏用户的真实身份看似能够有效隐藏，其实不然。伴随着大数据技术的发展，社会工程学的进步，通过对大量交易数据、行为数据进行挖掘和分析，完全有可能梳理出匿名地址与真实世界的直接或间接的关联信息，从而追溯到用户的真实身份信息。
- 此外，一些敏感、机密数据被直接上传到链上，即便是密文上传，一旦破译口令泄露，随后想要删除极其困难，造成机密数据的永久泄密。这都给区块链数据的安全带来了挑战。

区块链主要安全问题

私钥保存安全问题

- 近年来因私钥被黑客窃取而发起的区块链攻击事件频繁发生，可能导致用户信息外泄、账号盗用、资产丢失等安全事件，直接影响区块链生态的健康繁荣。如著名的“Mt.Gox 事件”。Mt.Gox 曾是当时世界最大的比特币交易商，但是因2014年遭黑客攻击而损失过大，无法偿还用户资产，而被迫宣布破产。2020年年初，黑客利用社会工程学手段，成功入侵并盗取某交易所万余枚用户账号后，再利用二级市场大量抛售获取巨额非法收益。
- 私钥保存安全问题主要包括私钥保存不当、私钥泄露等，可采用冷钱包、纸钱包方式保障私钥保存安全。
 - “冷钱包”又称为离线钱包，包括硬件钱包、纸钱包和脑钱包。这类钱包属于不需要联网也可完成交易的软件应用或硬件设备。
 - 硬件钱包是一种将用户私钥单独存储在安全加密芯片上的钱包。其在处理支付信息时不需要联网，根据设备自身存储的加密信息以及随机生成的种子密码来获取私钥和地址。通过联网软件扫描冷钱包的二维码，完成加密数据的传输以及交易的处理。
 - 纸钱包是一种将用户公钥和私钥保存在纸质载体上的应用模式。其私钥在无联网状态下生成且保存，不存在因联网而被盗的可能。脑钱包与纸钱包原理类似，区别在于脑钱包是将用户公钥、私钥保存在人类脑海里，而非纸质载体上。通常来说，脑钱包会利用一个人脑可以记住的短口令，通过一定的变换手段得出私钥。但是由于黑客会对常见单词进行穷举，一般来说如果脑钱包口令过于简单，容易遭到暴力破解。

区块链主要安全问题

系统机制安全问题

■ 网络与存储

- 主要是区块链网络中节点组网、数据传输、数据存储所面临的安全风险，包括节点间的连接质量、节点身份的伪造和假冒，数据传输中的监听和窃取、数据存储的丢失和恶意篡改等-系列影响保密性、完整性、可靠性的安全问题。

■ 数据结构与算法

- 主要是采用安全程度低的加解密算法、加解密算法编码缺陷、数理逻辑结构异常导致解析错误、交易数据树结构设置不合理等安全风险。加解密算法和数理逻辑结构若没有前沿密码学理论作为支撑，程序员实现的加解密算法存在代码缺陷，或错误实现加解密算法，都会导致区块链应用面临巨大的安全风险。

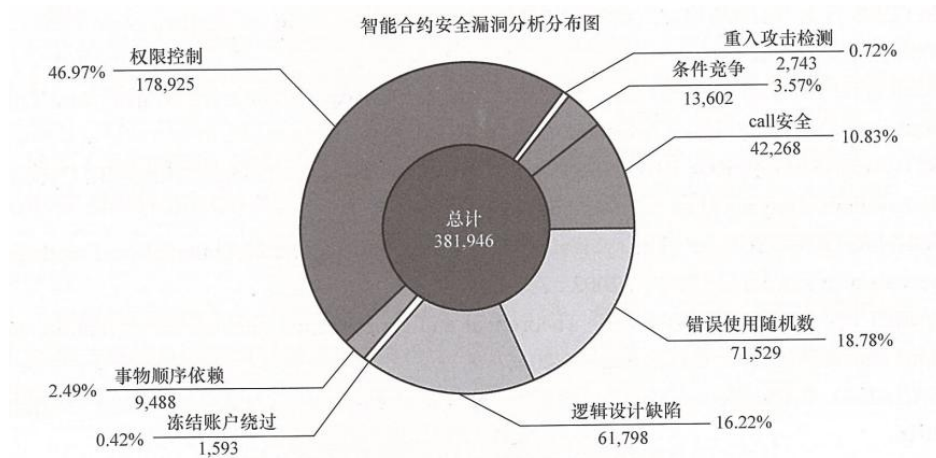
■ 共识机制

- 主要是一些不当的机制会遭到作恶者的利用，例如容错率低的共识机制、基于投票的机制等会遭到女巫攻击，从而带来安全问题。典型共识机制攻击包括如51%攻击、女巫攻击、日蚀攻击、分布式拒绝服务攻击等
 - 51%攻击：个人或机构通过某种手段掌控51%以上的节点算力，以影响区块链正常运行，篡改节点数据的一种攻击手段。51%攻击曾一度被认为不可能发生，然而伴随着矿池的中心化趋势，51%攻击的可能性也越来越大。
 - 女巫攻击：个人或机构通过伪造多个节点身份，以欺骗周边节点的信任，改节点数据的一种攻击手段。在区块链网络中，创建新身份或新节点往往是不需付出代价。其常见的攻击方式主要有:直接通信、间接通信、伪造身份、盗用身份、同时攻击、非同时攻击等。发起女巫攻击主要有三个步骤：伪造虚假节点加入→误导节点路由选择→发布虚假资源。

区块链主要安全问题

底层开发安全问题

- 底层开发安全问题中，智能合约开发面临的安全问题最为突出。智能合约作为区块链的核心技术之一，可以自动执行程序，按事先编写的业务逻辑去存储、接收和发送信息以及数字资产。其极大地提升了区块链的应用前景，但也面临着各类安全风险。
- 首先，由于智能合约可以存储大额的数字资产，对攻击者有很强的利益吸引；其次，许多智能合约代码在区块链上都是公开的，使得它们更容易被恶意人员去研究攻击；第三，智能合约通过共识部署在链上，部署后也无法修改。尤其是功能强大的智能合约，其逻辑越复杂越容易出现逻辑漏洞，而一旦出现安全漏洞，修复漏洞的成本也会非常高；最后，当前合约编程语言、合约运行环境及合约开发模式相比传统软件工程领域还不完善，也是导致安全漏洞产生的潜在风险。



智能合约安全漏洞类型分布图

项目设计的安全性分析

区块链系统是一种分布式的计算机信息系统。它与所有计算机信息系统一样，当系统形成较大规模应用时就会形成“网络效应”，从而产生巨大的应用价值。“安全”则是保证其大规模应用的关键。



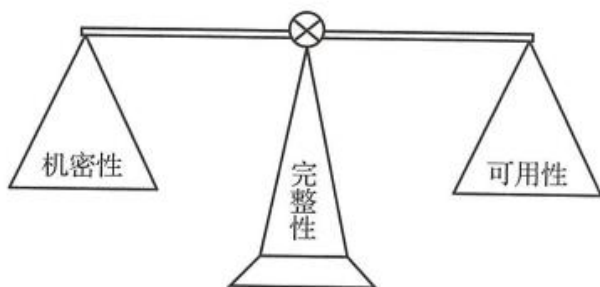
区块链信息的安全属性

■ 信息安全三要素

1. **机密性(Confidentiality)**: 使信息不泄露给未授权的个人、实体、进程, 或不被其利用的特性。即确保信息只被授权用户使用。常见的机密性保护手段包括: 密码学加密等信息保密技术, 防窃听和防辐射等电子保密技术, 限制、隔离、掩蔽控制等物理保密措施, 认证(Authentication)及授权(Authorization)等访问控制措施。
2. **完整性(Integrity)**: 使信息数据没有遭受以未授权方式所作的更改或破坏的特性。即确保信息只被授权用户修改, 而在使用、存储、传输等过程中都保持一致性。常见的完整性保护手段为密码学中数字签名(DigitalSignature)技术。
3. **可用性(Availability)**: 已授权实体一旦需要就可访问和使用的数据和资源的特性。即确保信息必须在业务需要时可被访问。可用性保护涉及对节点、网络、存储、计算、身份、软件等的保护, 任何对这些对象的攻击和破坏, 都可能损害可用性。

区块链信息的安全属性

■ 三要素的关系



- 完整性是天平的支柱，一旦完整性得不到保障，机密性和可用性就毫无意义。如口令被非法篡改后，口令的机密性也已经被破坏，同时口令也变得不再可用。
- 机密性和可用性分别在天平的两端，两者相互制衡。机密性越强，则可用性相对被削弱；而可用性越强，则机密性也相对被削弱。
- 在实际应用中，需要综合起来权衡考虑，而不能只片面强调部分安全。绝对安全是不存在的，信息安全保护是一个动态平衡的过程，在这个过程中，核心关键点是保护安全规则，而定义安全规则需要在业务需求和安全风险之间权衡。

区块链信息的安全属性

一、机密性

区块链主要采用数据隔离、地址匿名和信息加密方式提升机密性。

■ 1. 数据隔离方式

区块链系统可以采用类似传统数据库分库、分表的方式，将交易信息按照一定规则分散记录在多个子账本中，从而达到两个效果：一方面实现交易扩容，支持更大的交易规模和交易性能要求；另一方面实现数据隔离，不同用户只允许访问部分子账本从而增强了交易隐私性，提高了交易机密性。

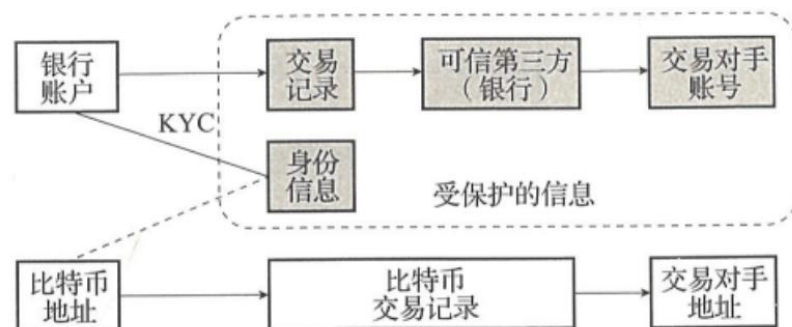
区块链信息的安全属性

■ 2. 地址匿名方式

比特币系统作为首个区块链和加密资产应用，就是采用账户地址匿名化来提高比特币交易双方信息的机密性。比特币系统作为首个区块链和加密资产应用，就是采用账户地址匿名化来提高比特币交易双方信息的机密性。

支持账户地址的“匿名性”

1. 账户地址生成不经过客户身份识别(Know-Your-Customer, KYC)，完全由用户自己产生，是根据椭圆曲线算法产生的公钥，再经过SHA256和RIPEMD-160哈希计算和 Base58 编码等变化的结果。
2. 无法直接通过账户地址，对应到真实身份信息。
3. 一个拥有者的多个账户地址之间无直接联系，其他人无法得知用户实际拥有的比特币数量。



比特币系统的隐私模型

区块链信息的安全属性

公开账本机制在机密保护上的问题

1. 比特币账户地址只是“半匿名”，无法做到完全匿名化

- 用户需要在交易中公开其公钥以便其他节点验证交易有效性，从而暴露了用户地址使用信息
- 交易信息公开，只需知道一个地址就可以找到关联人的一系列地址
- 对区块链数据分析，交易的汇总输入会暴露拥有人的其他地址
- 比特币协议未对通信数据进行加密，协议分析软件能够从比特币交易信息中分析出IP地址与比特币地址的对应关系
- 比特币交易所的实名认证机制，让交易所能够直接将用户信息与地址信息进行关联。

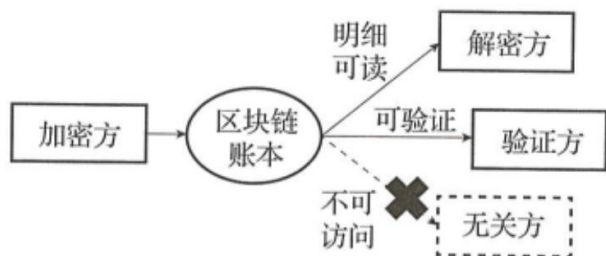
2. 比特币系统没有对交易金额进行机密性保护

- 由于比特币作为公有区块链，需要公开其全部账本，并让所有参与方都能正常读取账本中的历史交易信息，以便对交易正确性进行验证，共同防范“双花”等异常交易。但同时，这也给交易隐私带来了巨大威胁，损害了交易信息的机密性。

通常可采用多个账户地址、混币交易、隐蔽地址和环签名技术来改善其匿名性和机密性不足的问题。

区块链信息的安全属性

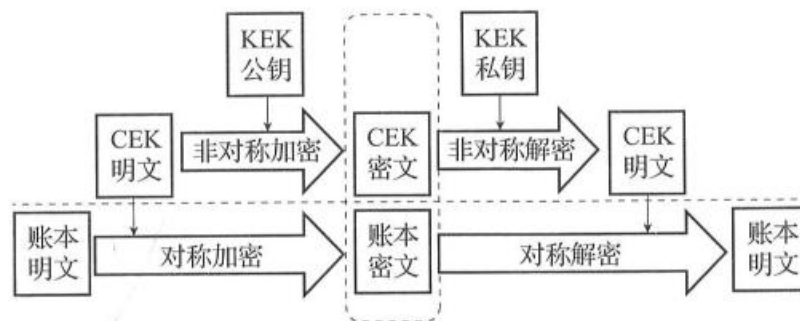
3. 信息加密方式



区块链账本信息的相关方

- 加密方：指当前业务请求方，对提交区块链的交易信息进行加密处理
- 解密方：指其他业务参与方，需读取并解密账本，获得交易详情以便进行相关业务操作
- 验证方：通常是区块链共识节点，需对新产生账本区块中的交易数据进行有效性验证，防止超额消费、双花交易等异常交易。但由于其不参与实际业务流程，其实并不需要了解交易详情。

- 区块链账本信息不仅有“机密性”要求，还有“可验证性”要求
- 对于私有链和联盟链这两种许可型区块链而言，验证节点是相对固定而且是预先知道的，可以使用传统密码学加密方式提高机密性。
- 可以将区块链账本数据、交易数据、配置数据以及账本元数据等，分别进行整体加密或局部加密；前者加密整个账本内容，后者只加密账本中涉及敏感信息的部分内容。此时，可以采用对称加密方式、非对称加密方式加密账本；也可将两者结合起来使用，既保证机密性，又保持较高的加密、解密效率。
- 内容加密密钥(Contents EncryptingKey, CEK)用于加密账本内容
- 密钥加密密钥(KeyEncryptingKey, KEK)则用于加密CEK本身。



区块链信息的安全属性

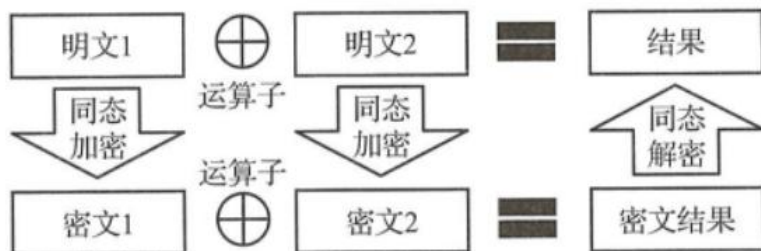
对于公有链这类非许可型区块链而言，由于无法预知谁是验证节点，因此很难简单运用传统加密方式来同时满足机密性和可验证要求。此时，需要引入同态加密或零知识证明等前沿技术。

(1) 同态加密技术

用于解决代数运算中的隐私保护难题。当对密文执行的运算，等价于对明文执行了同样的运算时我们把这种加密方式称为“同态加密”。在区块链和加密资产场景中，可以在保持交易金额机密性的同时，还能让区块链共识节点完成交易的验证，可防止“超额消费或“双花”等异常交易。

(2) 零知识证明

证明者能够使验证者相信某个论断，而无须泄露除了“论断是真实的”之外的任何信息。在区块链和加密资产场景中，可以在保持交易信息机密性的同时，还能让区块链共识节点完成多种交易验证，确保账本的有效性。



区块链信息的安全属性

二、完整性

实现区块链的高度防篡改性，为区块链账本带来完整性保障

数字签名

基于非对称密码学技术实现账本交易信息的防篡改性和不可抵赖性。

空间维度

基于分布式共识机制，能够让不同空间的多个参与主体共同维护账本数据，提高账本的可信度。

时间维度

采用块链结构和时间戳，设计一整套精巧的数据结构来组成账本链条，其中每个区块账本的每一条交易记录都层层受到密码学原理保护。而且随着时间的增长，篡改的难度也成指数级增长

区块链信息的安全属性

数字签名	共识机制	块链结构	时间戳
在区块链中，每一笔交易或每一次对区块链状态的改变都需要交易或者状态改变的发起者用其私钥来签名。区块链的参与节点必须用发起者的公钥来验证签名。如果签名验证没有通过，交易是不可能被区块接受的。从数据安全的角度来思考，数字签名的主要作用是可以做到某种程度的抗抵赖性。交易的双方都需要用私钥对交易进行签名来确认，交易发生后双方就不能抵赖，这样可以从某种程度上保证交易数据的完整性。	区块链上任何数据的增加都需要遵循共识机制。黑客也许可以修改某几个区块链节点的数据，但是除非他拥有51%以上的算力(比特币网络)或者拥有大部分的代币(以太坊网络)，否则篡改数据成功的概率趋近于零。简单来说，就是全局的共识一定能够战胜局部的篡改，从而在整体上保障了数据完整性。	块链结构(Block-Chain Suructure)是区块链系统的典型数据结构。上链数据通过共识机制打包在一个新区块中，同时通过哈希指针链接到前一个区块，随着区块的不断叠加，这些上链数据都成了链上不可篡改的数据。从创世区块到当前区块，在区块链之上的所有数据历史都可以追溯和查询到，这样数据的完整性在数据上链的过程中得到了保障。	时间戳通常是一个字符序列，用以唯一地标识某一刻的时间。在比特币系统中，获得记账权的节点在链接区块时需要在区块头中加盖时间戳，用于记录当前区块数据的写入时间。每一个随后区块中的时间戳都会对前一个时间戳进行增强，最终形成一条时间递增的链条如果想要篡改记录，那么篡改的时间就会打乱时间戳递增的顺序，从而无法实现隐蔽性修改的目的。换句话说，时间戳有利于原始记录的保存，使其具有不可篡改性。

区块链信息的安全属性

三、可用性

在软件系统中，可用性定义为系统功能和工作时间的比例。可用性受到系统错误基础设施恶意攻击和系统负载的影响。它通常以正常运行时间的百分比来衡量，是系统性能的一个指标，确保在合理的时间内响应用户的请求。

区块链系统通过在网络、存储和计算等方面实现极大的冗余部署，从而具有较强的可用性，可提供24x7全天候高可用运行能力。

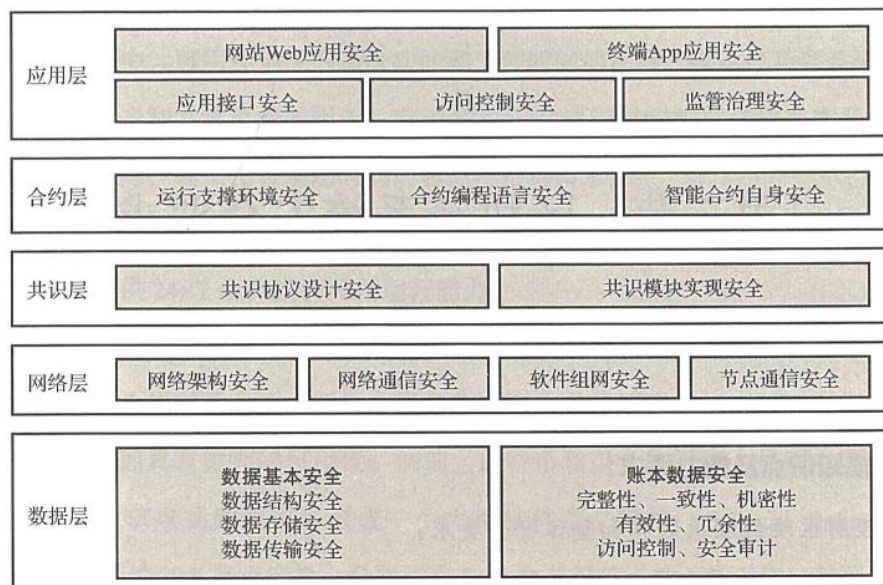
■ 网络方面

- 区块链系统基于已有网络，实现全球大范围多节点部署运行，在满足共识机制最小组网要求下，即使大部分节点因为各种原因宕机，也不会影响整个网络的运行，从而具有极大的可用性。例如，比特币和以太坊网络，分别由全球分散的上万个左右的节点共同组网，形成一个大型软件定义网络 (SoftwareDefined Net-work; SDN)，哪怕99%节点宕机，只要还有3~5个共识节点能正常工作，其可用性就不受影响。

■ 存储和计算方式

- 每个区块链全节点都独立存储区块链全量账本数据的副本，并能根据副本数据独立完成账本验证，以及智能合约的执行，因而具有很强可用性
- 从性能考虑，区块链由于具有冗余多副本，增加了读取操作的可用性；但由于需要通过共识机制实现多副本的一致性，导致其写入操作的可用性较低，尤其与中心化系统相比差距较大。

区块链系统的安全要求



区块链系统安全体系结构

- **数据层安全：**综合使用一系列密码学技术，从账本结构、存储引擎、隐私保护、冗余机制、访问控制、安全审计等多个方面确保数据的完整性、一致性、机密性和有效性等安全属性。
- **网络层安全：**从硬件网络架构、动态软件组网、网络通信、节点通信等方面确保网络层安全。
- **共识层安全：**基于安全的共识协议和共识算法，实现安全可靠的共识模块确保分布式场景下的各节点账本的一致性。
- **合约层安全：**合约层安全是实现区块链可扩展和可编程特性的基础，其安全属性涉及智能合约的运行支持环境、智能合约的编程语言，以及智能合约本身的安全。
- **应用层安全：**面向用户的应用系统安全，包括网站Web应用、终端App应用的安全性，以及应用接口、访问控制、监管治理等方面的安全性。

区块链系统的安全要求

一、数据层

- 在数据层，区块链系统除了需要从数据结构、数据存储、数据传输等基础软件层面考虑安全需求，还需要重点评估区块链账本数据的安全需求。
- 账本数据格式是区块链基本特征之一，各个区块链系统都有自己定义的账本数据格式，评估体系不能对格式具体进行定义，这不符合业务多样性的要求。从用户的角度，以黑盒标准来衡量账本数据的安全性是一个比较好的选择。账本格式可以按机构业务自行定义，账本数据评估可从数据的完整性、一致性、机密性、有效性和冗余性等方面来要求，同时还需要满足数据访问控制和数据安全审计的要求。

区块链系统的安全要求

区块链数据基本安全要求

- (1)数据结构防篡改：账本结构宜使用链式或近似链式的存储结构，应使用哈希嵌套保证数据难以篡改。
- (2)数据结构可校验：任何一条记录被非法篡改后都可以通过历史账本数据回溯以快速检验出来。
- (3)数据分类隔离：应根据数据对象的类别，如账户数据、交易数据、配置数据以及账本元数据等，进行分别存储、分别管理、分别操作。
- (4)敏感数据安全：应加密存储，并应有数据访问等权限的控制和管理
- (5)密钥数据安全：应私密管理，确保区块链节点数字证书及其私钥数据存储安全
- (6)数据库安全：数据库版本应选用安全高效并经过检验的主流稳定版本；数据库类型可选用结构化数据库(如关系型数据库)或非结构化数据库(如键值型数据库、文档型数据库等)，或混搭多种类型的数据库
- (7)数据传输安全：应在传输过程中，使用对称或非对称的国密算法对数据进行加密，防止数据被窃取

区块链账本数据安全要求

- (1)完整性：应保证账本数据的生成、传输、存储、调用等操作不可被非授权方式更改或破坏。
- (2)一致性：区块链账本中记账节点的账本数据应保持一致；对账本数据的写入和修改，须经各节点达成共识，以确保各节点的数据一致性。
- (3)机密性：应采用密码技术保证账本数据中的敏感数据在传输和存储过程中的机密性；账本数据中敏感数据的保护密钥和账本数据本身应分开保存，并且保护密钥应支持存放在安全的密码模块中。
- (4)有效性：各记账节点的账本数据应符合共识协议安全要求，保证账本数据的有效性，且满足以下要求：应能够对节点存储的账本数据有效性进行校验；当某个节点的账本数据失效时，保证系统整体上账本数据的有效性。
- (5)账本数据冗余性：应保证账本数据在系统中具有冗余性，防止因单个节点失效而造成总账本数据的丢失。
- (6)访问控制：区块链账本应确保账本数据不被未授权的第三方获取，因此数据访问和操作应符合访问控制安全要求中隐私保护部分对认证授权、访问控制等方面的技术要求。
- (7)安全审计：记账节点对账本数据的操作应满足以下安全审计要求：账本数据的访问应提供安全审计功能。

区块链系统的安全要求

二、网络层

■ 网络架构连通性要求

- 网络架构应保证共识节点或记账节点之间能够直接进行网络通信或能够间接进行消息传递；网络架构应防止单个节点故障而形成网络隔离，防止“脑裂问题”。

■ 网络通信安全性要求

- 应在参与区块链节点之间建立安全传输通道，保证数据传输的完整性和不可改性；应对数据和信息采取相应的防护措施，保证其能够抵抗篡改、重放等主动或被动攻击；应采用密码技术保证节点间通信过程中敏感信息字段或整个报文的机密性，应确保信息在存储、传输过程中不被非授权用户读取和篡改；可采用有权限的网络访问控制，在区块链参与节点之间构建虚拟专用网络，降低网络攻击造成的危害。

■ 软件组网安全性要求

- 各软件节点应基于网络通信协议和P2P网络进行通信和数据互换：各软件节点独立存储账本数据的一致性副本，且保证任意单个节点故障都不影响整个系统的正常工作：各软件节点具有独立的通信控制功能，且任一节点均至少与其他两个节点建立通信连接；各软件节点分布在不同地点，通过节点互联形成一种软件定义网络(SDN)网络中可无中心节点。

区块链系统的安全要求

- 节点通信安全性要求

- 区块链系统采取节点授权准入的原则，在节点通信过程中应保证数据的完整性机密性。
 - 节点身份验证：应使用符合“身份管理”章节中要求的身份认证机制控制节点的接入；采用密码技术对节点通信双方的身份进行验证。
 - 通信完整性：应使用符合国家密码标准的消息鉴别码算法、数字签名等密码技术来提供通信中数据的完整性保护和校验：节点间通信协议应具备应对通信延时中断等情况的处理机制：当检测到数据的完整性遭到破坏时，接收节点可以采取从发送节点处重新获取数据。
 - 通信机密性：在通信节点建立连接之前，应使用符合国家密码标准的密钥交换技术来产生双方共享的工作密钥，并进行双向身份认证，确保通信节点是信息的真实授权方；通信节点应当使用工作密钥对通信过程中的整个报文或会话进行加密处理：应使用符合国家密码标准的技术来建立安全通信通道，避免因传输协议受到攻击而出现的机密性破坏。

区块链系统的安全要求

三、共识层

■ 1. 共识协议设计安全要求

- 合法性：应确保参与共识过程的节点经过验证，保证节点加入和退出共识过程的合法性，以及节点ID与节点实体的一一对应，以形成可信节点
- 正确性：共识协议依据的算法理论应公开发表或经过安全评估，如有修改应经过同行评议；协议算法的测试应全面完整，应用形式化验证或进行代码审计以确保算法实现的正确性；可信节点应为协议算法的运行提供安全可信的硬件和软件基础确保协议算法运行环境的安全性及可靠性
- 终结性：算法应在可接受的有限时间内具有终结性。所有参与共识的可信节点，经过一段可接受时间内的交互，应最终达成一致结果
- 一致性：所有参与共识的可信节点得到的计算结果应是相同的，且符合共识协议。
- 不可伪造性：系统中恶意节点占比不超过共识协议容错率(例如，采用PoW共识时该比率为1/2，采用PBFT共识时该比率为1/3)时，任何对系统当前状态进行恶意构造以欺骗其他可信节点所需要的时间，应不少于可接受范围。
- 可用性：协议应具备抗分布式拒绝服务(Distribution Denial of Service, DDoS)攻击、处理恶意报文、识别恶意节点的能力，且应采取不转发、拒绝连接、黑名单等措施缩小影响，使系统获得一定的主动防御能力，提高系统的可用性；系统能够始终在正常时间内对客户端的请求进行响应

区块链系统的安全要求

■ 1. 共识协议设计安全要求

- 健壮性：在遭受恶意攻击、数据被污染时，被攻击节点应通过与系统中其他可信节点交互等方式来检测出攻击及数据污染的发生；系统中的节点如遇到网络故障等情况与系统断开连接，可能会出现与系统中其他节点状态不一致的情况，但在恢复连接后，通过与系统中其他可信节点的交互等干预方法，保证节点数据恢复正常状态不会丢失受攻击前的数据，并保持和正常节点间数据的一致性。
- 容错性：系统中恶意节点占比不超过共识协议的容错率时，系统应保证正常运作，且保持数据一致性。
- 可监管性：单次共识过程和系统运行的整个共识历史都应可审计、可监管该历史应不可被篡改。
- 低延迟：共识协议应保持低响应延迟，满足系统对于数据同步的时间要求
- 激励相容：采用激励机制保障系统安全，应计算系统可承载的价值上限并对其上的应用系统进行检查，避免超过安全阈值
- 可拓展性：协议应该具备动态拓展能力，可允许在系统保持正常服务的前提下动态或静态增删节点

■ 2. 共识模块实现安全要求

- 共识模块应能协调各系统参与方有序参与数据打包和共识过程，并保证各参与方的数据一致性
 - (1)在系统无故障、无欺诈节点时，共识模块能在规定时间内达成一致的、正确的共识，输出正确结果
 - (2)在故障节点数量或欺诈节点数量不超过理论值的情况下，系统也应能够正常工作，输出正确结果

区块链系统的安全要求

四、合约层

运行支撑环境安全要求

智能合约的执行应在可信的软件/硬件支持的环境中执行；智能合约代码存储和运行时，系统应具备相应的安全保护能力，禁止未授权实体明文读取合约代码和状态；智能合约应能数据前向兼容，版本迭代时，旧版本的合约应及时停用并存档数据，新版本合约可以调用历史数据；智能合约的运行机制需有前向兼容的能力，当系统版本升级后，智能合约应能正常执行；系统应当通过有效的智能合约审核，以确保合约代码所表达的逻辑无漏洞。

合约编程语言安全要求

- (1)图灵完备的编程语言：兼容图灵机模型，可以用来解决可计算理论中任何“可计算问题”，具有很强的可编程性。传统计算机编程语言，如C/C++、Java 都属于此类。
- (2)非图灵完备编程语言：不兼容图灵机模型，只具备有限的可编程性，用于解决特定的问题。例如，比特币系统中的交易脚本，Libra区块链的Move语言都属此类。

智能合约本身安全要求

- (1)合约版本控制
- (2)合约访问控制
- (3)合约复杂度限制
- (4)合约原子性
- (5)合约一致性
- (6)合约生命周期管理
- (7)合约安全审计
- (8)合约安全验证
- (9)合约攻击防范

区块链系统的安全要求

五、应用层

应用接口设计安全要求

应用层通过相关接口与区块链系统进行交互，接口安全必不可少。首先，接口应具备良好的封装性，能够隐藏底层账本的细节，为应用层提供简洁的调用方法，防止被错误使用；其次，接口应具备完备性，提供完整的交易处理、账本处理功能，以及完善的权限管理机制；最后，接口设计还应考虑扩展性和兼容性要求。

访问控制安全要求

访问控制模块提供技术与制度手段，防止非法的主体进入核心区块链获取资源。允许合法用户访问、使用核心区块链，防止合法的用户对核心区块链资源进行非授权的访问。具体来说，分别从身份管理、隐私保护、密码算法这三个方面进行安全评估。

监管治理安全要求

- (1) 监管支持要求
- (2) 安全运维要求
- (3) 安全治理要求

网站Web应用安全

由于 Web 应用本身具有一些安全性弱点，其安全漏洞常受到攻击，从而破坏应用系统的安全性。这些安全弱点，主要来自：① TCP/IP 本身缺陷；② 网络结构的不安全性，形成单点故障、脑裂问题等；③ 网络窃听，容易导致信息泄露、中间人攻击等；④ 验证手段的有效性，难以识别用户真实身份；⑤ 人为因素，如安全配置错误，密码或密钥存储不当等。

终端APP应用安全

- (1) 静态分析
- (2) 动态防御
- (3) 本地数据安全
- (4) 网络数据安全
- (5) 身份认证安全
- (6) 系统环境安全

区块链安全测试方法

一、静态安全扫描

■ 介绍：

- 静态安全扫描是近年被人提及较多的软件应用安全解决方案之一。其核心是静态源代码分析技术，即在不运行代码的方式下，通过词法分析、语法分析、控制流分析数据流分析等技术对程序代码进行扫描，验证代码是否满足规范性、安全性、可靠性可维护性等指标的一种源代码分析技术。

■ 优点：

- 无须进行编译，也无须搭建运行环境，就可以对程序员所写的源代码进行扫描，从而节省大量的人力和时间成本，提高开发效率，并且能够发现很多靠人力无法发现的安全漏洞，站在黑客的角度上去审查程序员的代码，大大降低项目中的安全风险，提高软件质量。

■ 目前的技术：

- (1) 第一代静态扫描技术主要基于词法分析、语法分析技术。这些方式的缺陷是以代码所匹配的规则模式去评估代码，只要模式匹配或者相似就报出来。其缺点是存在较多的误报和漏报，需要依靠人工去分辨其中的准确性。当针对少量代码或简单代码时，该问题还不严重。但当针对大规模代码或复杂性代码时，传统的扫描技术将几乎不可行。
- (2) 第二代静态扫描技术进一步引入控制流分析、数据流分析等技术。通过把待分析的代码及代码之间的关系以对象的方式存放在内存中，同时也使用了一种可以接受的算法在有效的时间里描绘出应用的路径图形，并采用了一种特殊的查询语言(如 CxOL)，来查找安全问题，每一个查询语句就针对一类安全漏洞，从而大量减少误报问题。用户还可以定制查询规则，查找特定的安全和逻辑的问题，解决漏报问题，使得代码扫描变得更加现实和可用，节省大量的时间和人力成本。

区块链安全测试方法

二、动态安全扫描

- 静态代码扫描可以发现代码中的安全问题，但是当软件系统的各个组件集成到一起之后或者系统部署到测试环境后，仍然可能会产生系统级别的安全漏洞，如跨站脚步漏洞 XSS、跨站请求伪造漏洞CSRF、SQL注入攻击等安全问题，所以在这个时候对系统进行动态安全扫描可以在最短的时间内发现安全问题。
- (1) 主动扫描
 - 主动扫描是首先给定需要扫描的系统地址，扫描工具通过某种方式访问这个地址，如使用各种已知漏洞模型进行访问，并根据系统返回的结果判定系统存在哪些漏洞；或者实施模糊测试，即在访问请求中嵌入各种随机数据，进行一些简单的渗透性测试和弱口令测试等。对于一些业务流程比较复杂的系统，主动扫描并不适用。例如，一个需要登录和填写大量表单的支付系统，这个时候就需要使用被动扫描。
- (2) 被动扫描
 - 被动扫描的基本原理就是设置扫描工具为一个代理服务器，功能测试通过这个代理服务访问系统，扫描工具可以截获所有的交互数据并进行分析，通过与已知安全问题进行模式匹配，从而发现系统中可能的安全缺陷。一般在实践中，为了更容易地集成到持续集成系统，会在运行自动化功能测试的时候使用被动扫描方法，从而实现持续安全扫描。

区块链安全测试方法

三、系统漏洞扫描

- 漏洞扫描是指基于漏洞数据库，通过扫描工具对指定的远程或者本地计算机系统的安全脆弱性进行检测，发现潜在漏洞的一种安全检测行为。这些漏洞可能存在于防火墙、路由器、交换机、服务器等各种应用之中。漏洞扫描过程是自动化的，专注于网络或应用层上的潜在以及已知的漏洞。该方式能够快速发现存在的风险，但发现的漏洞不够全面，是企业和组织进行信息系统合规度量 and 审计的一种基础技术手段。
- 漏洞扫描技术主要涉及：①主机扫描技术：确定在目标网络上的主机是否在线；②端口扫描技术：发现远程主机开放的端口以及服务；③操作系统识别技术：根据信息和协议栈判别操作系统及其版本；④漏洞检测数据采集技术：按照网络、系统、数据库进行扫描；⑤智能端口识别、多重服务检测、安全优化扫描、系统渗透扫描；⑥数据库自动化检测、版本识别、实例发现等技术；⑦密码生成技术：提供口令爆破库，实现弱口令检测。
- 针对扫描的对象不同，漏洞扫描器有多种产品，主要包括：①网络漏洞扫描器通过网络来远程扫描计算机中的漏洞，优点是简单易实施，缺点是能扫描的漏洞类型较少。②主机漏洞扫描器，通过在目标主机系统上安装的代理或服务，能够访问所有的文件与进程，从而扫描到更多的漏洞。③数据库漏洞扫描器，检测出数据库管理系统漏洞、缺省配置、权限提升漏洞、缓冲区溢出、补丁未升级等自身漏洞。随着主流数据库的广泛应用，其自身漏洞逐步暴露，数量庞大，仅通用洞披露 (Common Vulnerabilities & Exposures, CVE) 公布的 Oracle 数据库漏洞数已超千个。

区块链治理

区块治理的定义和目的

- 治理(Governance)是理解区块链的一个视角。治理本是一个政治学术语，通常指国家治理，即政府如何运用国家权力(治权)来进行决策，以管理国家和人民。近年来，治理的概念不断向外延伸。在商业领域，公司治理(Corporate Governance)指公司等组织中的管理方式和制度等。在 IT 领域，IT 治理指企业有关 IT 决策权的归属机制和有关 IT 责任的承担机制，鼓励IT应用的期望行为的产生，以连接战略目标、业务目标。
- 契约是理解治理问题的钥匙。治理之所以有必要，是因为现代人类组织实际上是一系列契约的集合。契约的订立、维护和执行过程，也就是治理的过程，是一切组织的运行过程中最重要的组成部分。
- 网络社群是指由网络连接、具有明确的成员关系、一致的群体意识和规范，并围绕一组特定目标进行持续互动和分工协作的人群组织。相比于传统的人群组织，网络社群规模和结构差异巨大，范围模糊，并且跨越各种传统的组织边界，个体之间比较平等，连接相对松散、动态，激励和管理手段比较有限。但与此同时，网络社群蕴藏着巨大的经济潜力和创造力。网络社群治理指网络社群中的利益相关方协调行动，做出决策和实施决策的过程，包括决策和规则的建立、维护、实施、调整、废止等。
- 区块链治理的讨论源于比特币独特的社群发展模式。比特币创始人中本聪在比特币发展早期就不再出现于网络。自此之后，矿工、开发者、交易者和爱好者组成了比特币社群，在并没有一个中心机构负责协调运营的情况下，围绕写入比特币代码中的若干简单规则进行互动与协作。而这种互动与协作，使得比特币在十年时间中成长为一个影响亿万人的知名项目，更为其早期参与者带来了不菲的收入。
- 区块链治理要解决的问题是：如何发挥区块链的技术特点，在区块链网络组织内相关利益各方之间建立和维护有效的契约，并确保契约得到高效执行，从而促使网络组织向目标方向发展

区块链治理的特点

- 代码化治理：区块链社群倾向于将尽可能多的治理规则以代码表达，并且发布在区块链上，利用代码的精确性和区块链不可篡改的特点，确保治理规则清晰、无歧义、可靠可信。
- 透明：区块链社群普遍要求一切治理规则公开透明，其中代码化的规则需要开放源代码，非代码化的规则也需要公布。
- 自动化：由于大量的治理规则由代码表达，因此能够以智能合约的形式自动执行，减少人为的干预
- 低成本、高效率：同样由于治理的代码化、自动化，大量的治理决策可以在短时间内精确执行，并且成本极低
- 设备友好：区块链可以与智能设备相结合，从而将设备转化为执行规则的工具，例如根据区块链上定义的治理规则来决定一间房屋的智能门锁是否开启
- 安全敏感：如果治理规则存在漏洞，或者实现代码存在错误，则可能被利用而导致错误，可能造成重大损失，并且纠正成本高昂。因此对于规则制定的严密性、可靠性以及代码的正确性要求非常高。
- 契约刚性：区块链上的治理契约，一旦部署完成，将会按照预定程序不折不扣的执行不以任何个人和组织的意志为转移，回滚的代价往往很巨大，因此具有鲜明的刚性
- 分布式自治组织(Decentralized Autonomous Organization, DAO)是区块链上分布式社群治理的重要尝试。

区块链治理机制设计

■ 参与角色分析

- 区块链社群通常是一个开放组织，因此其治理主要是在开放条件下，在不同利益相关方之间创建契约关系。不同的利益相关方是依据其在契约当中的权利义务关系划分的，同一类利益相关方可以划入同一角色，也就是说治理是在不同角色人群当中发生的，本质上是在不同角色人群之中建立和执行契约的过程
- 系统：代表区块链组织整体的拟人化角色，由自动化执行的智能合约和程序，以及按照事先约定并得到批准的算法负责与其他角色进行交互。
- 社群成员：区块链社群的普通成员是参与和接受治理的基本角色
- 治理中心：绝大多数区块链社群都会设置一个中心化的治理组织，一是为了提高决策效率，二是为了在契约没有约定的情况下代表全体社群成员实现快速决策，在经济学上称为“行使剩余权力”。在项目实践中，通常设立基金会、联盟等组织作为治理中心
- 开发者：区块链项目通常都需要技术人员持续进行开发、升级、修复错误等工作，某些具有平台性质的项目还需要大量的第三方为之开发扩展应用，因此开发者是区块链治理当中不可或缺的角色
- 合伙人：区块链社群中集中承担义务并享受权利的角色，在很多项目中被称为“节点”
- 外部用户：如果区块链项目提供了可供外部使用的功能，那么，不直接属于社群但在外部与区块链项目互动的人，也应当作为外部用户被纳入治理体系进行分析。

区块链治理机制设计

■ 描述契约

- 角色清晰之后，应当明确地以文字方式规范地描述各角色之间的契约关系、契约行为和权利义务
- 比特币中系统、矿工与用户之间的契约关系可描述如下：
 - 用户持有比特币，并且可以自由的进行转账交易
 - 矿工负责维护比特币账本，诚实记录每一笔转账交易，拒绝不合格的交易请求
 - 系统负责对矿工的诚实行为予以奖励，对欺诈行为予以惩罚
- 在实践中，通常需要把契约写入区块链或智能合约系统以保证契约执行

■ 治理工具设计

- 治理需要工具，一方面治理者需要尽可能完整、准确地掌握整个区块链系统和社群互动的信息;另一方面，也需要能够及时地施加激励或惩罚，这都需要相应的工具。到目前为止，通证(Token)是区块链中实施治理的最主要工具。
- 通证是在区块链上创建的数字对象，具有全局唯一、可流转、可编程、不可复制、不可修改、易于验证等特点，因此特别适合用来代表价值。或者更具体的说，通证可以作为数字化的价值智能合约。在区块链治理当中，通常使用有价值的通证作为激励工具，激励参与者完成契约行为。
- 很多情况下，为了完成复杂的契约行为，需要设置多个不同类型的通证，相互组合。根据通证所代表的价值合约的性质，可以将通证划分为如下几类：权益性通证、功能性通证、外部资产通证

区块链治理机制设计

博弈机制设计

- 区块链治理的一个特点，就是通过激励和博弈机制，实现“激励相容”，即让每一个角色追求自身利益最大化行为与契约行为统一起来。经济学当中的理想市场机制，就是一个激励相容的机制。但市场机制的目的是均衡，而不是发展。通常区块链系统有强烈的发展目标，因此需要主动设计博弈机制，以推动各个角色在追求自身利益的过程中推动系统的整体发展
- 区块链治理中的博弈机制设计是一个复杂、实践性强且多样化的工程，主要有以下三点考虑：
 - 采用理论与经验结合的形式。经济学现有博弈论和机制设计给予了区块链治理一定的理论技术，但在解决复杂问题当中还存在局限性。因此在实践中还需要充分借鉴经过历史检验的机制，如最低工资、奖金、提成、保证金、罚款、债券、股权、期货、期权等，是历史验证有效且人们比较熟悉的机制。在博弈机制设计当中，应尽可能借鉴上述机制，且做到简单明了。发明全新的博弈机制在实践中具有不可知的风险，如果其中存在漏洞，可能导致整个系统在治理上被攻击甚至失败。
 - 充分认识短期利益与长期利益的关系。通常的博弈机制设计都要求参与者在短期利益与长期利益之间做权衡，不能鼓励参与者为了追求短期利益而采取对长期利益有害的行为。这也是博弈机制设计其中的一个重点和难点。
 - 将剩余权力交给权益最大、流动性最差的利益相关方。经济学家很早就意识到，所有契约都是不完备的，因此无论如何设计完善契约规则，总会有很多情况无法覆盖。对于这些无法覆盖的情况，也需要分配决策和管理的权力。在经济学上，将这些处理契约规定之外的情况的权力称为剩余权力。剩余权力应当分配给在整个系统中权益最大而且流动性最差的角色因为只有这样的角色才会被迫从长期利益出发，选择最符合系统长远利益的决策。权益较小并且流动性很好的角色，很容易采取机会主义行为。

区块链治理机制设计

管理机制设计

- 如果将博弈机制设计视为“立法”的过程，管理就是“行政”的过程。任何契约都是不完备的，都会遗留很多情形，由剩余权力的掌握者，也就是管理者来管理。在区块链治理实践当中，这是一项巨大的权力，因为能够用代码完整表达的契约通常是一小部分也就是说大多数日常决策可能都是交由管理者来负责的。这往往与区块链社群的“初心”相悖。为此，区块链治理机制设计中需要对于“管理者如何管理”这一问题进行设计。包括核心机构人员的产生、议事规则、投票制度等。这一设计过程与当代民主政治体制有诸多相通之处。